

INCIDENT RESPONSE

BUSINESS CONTINUITY & DISASTER RECOVERY

Practical Manager and Junior Analyst Manual

What this manual does: Shows how to prepare for disruption, detect and manage cyber incidents, continue critical services, restore technology safely, test evidence, use open-source tools, and build job-ready analyst skills.

Alberto (Al) Leiva

First Edition • July 2026

Preface

Incidents and disruptions do not follow a convenient script. A cyberattack can become a legal, safety, customer, financial, operational, and reputational crisis. Good resilience connects incident response, business continuity, disaster recovery, crisis leadership, communications, suppliers, and continuous improvement.

This manual uses plain language and realistic work products. It is not legal advice or a guarantee. Requirements vary by organization, sector, contract, country, regulator, technology, and event. During a real emergency, follow approved authority, preserve safety and evidence, and involve qualified legal, privacy, human resources, communications, insurance, law-enforcement, and technical professionals as appropriate.

Current-information note: Official guidance was checked on July 14, 2026. The incident-response foundation is NIST SP 800-61 Rev. 3, finalized April 3, 2025. Continuity content also uses NIST SP 800-34 Rev. 1 Update 1 and ISO 22301:2019 with Amendment 1:2024.

How to use this manual

- Managers: begin with Chapters 1–5, 7, 9–13, 19–25, and 27.
- Junior analysts: study in order and complete Chapters 26–29 with synthetic data and authorized labs.
- Technical responders: focus on Chapters 5–18, 21–24, and 26.
- Continuity and recovery teams: focus on Chapters 3, 11, and 19–24.
- Tailor every plan, threshold, contact, requirement, and exercise to the organization.

Table of Contents

This document contains a native Word table of contents. The chapter guide on the next page is a permanent quick reference.

Preface.....	2
How to use this manual.....	2
Table of Contents	3
Chapter Guide	7
1. IR, Business Continuity, and Disaster Recovery Foundations	8
2. Governance, Policy, and Roles	9
2.1 Governance essentials	9
3. Risk Assessment and Business Impact Analysis.....	10
3.1 BIA method	10
4. Current NIST Incident Response Model.....	12
4.1 Practical operating sequence	12
5. Preparation and Readiness	13
5.1 Readiness checklist	13
5.2 Playbook design	13
6. Detection and Event Validation	14
6.1 Signal sources	14
6.2 Validation questions.....	14
7. Triage, Severity, and Escalation	15
7.1 Triage output.....	15
8. Investigation and Scoping	16
8.1 Investigation method.....	16
9. Containment Strategy	17
9.1 Options	17
9.2 Decision record.....	17
10. Eradication and Remediation	18
10.1 Eradication work	18
11. Recovery and Return to Service	19
11.1 Recovery gates	19
11.2 Recovery evidence	19
12. Lessons Learned and Improvement	20

12.1 After-action process	20
13. Communication, Legal, and Regulatory Coordination	21
13.1 Operating rules	21
14. Digital Evidence and Forensic Readiness	22
14.1 Evidence record	22
15. Ransomware and Destructive Attacks	23
15.1 Immediate priorities	23
15.2 Payment decision	23
16. Cloud and SaaS Incident Response	24
16.1 Cloud investigation	24
16.2 Cloud containment	24
17. Identity and Privileged-Access Incidents	25
17.1 Scope	25
17.2 Safe recovery order	25
18. Third-Party and Supply-Chain Incidents	26
18.1 Prepare	26
18.2 Respond	26
19. Business Continuity Management System	27
20. Continuity Strategies and Procedures	28
20.1 Continuity procedure	28
21. Disaster Recovery Planning	29
21.1 NIST SP 800-34 contingency process	29
21.2 DR plan content	29
22. Backups and Recovery Assurance	30
22.1 Design	30
22.2 Restore test	30
23. Crisis Management and Human Factors	31
23.1 Leadership rhythm	31
24. Exercises, Training, and Plan Maintenance	32
24.1 After-action evidence	32
25. Compliance Mapping, Evidence Testing, and Metrics	33
25.1 Evidence test	33
26. Open-Source Tools	34
26.1 TheHive	34

26.2 Cortex.....	34
26.3 MISP	35
26.4 Wazuh	35
26.5 Velociraptor	35
26.6 Volatility 3.....	35
26.7 Autopsy	35
26.8 Timesketch	36
26.9 Plaso / log2timeline	36
26.10 osquery.....	36
26.11 Zeek.....	36
26.12 Suricata	36
26.13 YARA.....	37
26.14 Sigma	37
26.15 DFIR-IRIS	37
26.16 GRR Rapid Response	37
26.17 Shuffle	38
26.18 OpenSearch	38
27. Manager's Resilience Playbook	39
27.1 Executive questions	39
28. Junior Analyst Career Guide and Portfolio Lab	40
28.1 Common roles	40
28.2 Typical work	40
28.3 Fictional portfolio lab.....	41
29. Thirty-Day Plan and Interview Preparation	42
29.2 What is the difference between IR, BC, and DR?	42
29.3 What is NIST SP 800-61 Rev. 3?	42
29.4 RTO versus RPO?	42
29.5 How do you triage an incident?	42
29.6 What makes evidence reliable?.....	42
29.7 When is recovery complete?	42
29.8 How do you close an improvement?	42
29.9 What should a junior analyst avoid?	43
29.10 Questions to ask the employer	43
30. Templates, Glossary, Index, and References	44

30.1 Incident case record	44
30.2 BIA and continuity record	44
30.3 Evidence and chain-of-custody record	44
30.4 Exercise and corrective-action record	44
30.5 Glossary	45
30.6 Subject index	45
30.7 Official references	46

Chapter Guide

Chapter	Title	Starts on page
1	IR, Business Continuity, and Disaster Recovery Foundations	5
2	Governance, Policy, and Roles	6
3	Risk Assessment and Business Impact Analysis	7
4	Current NIST Incident Response Model	9
5	Preparation and Readiness	10
6	Detection and Event Validation	11
7	Triage, Severity, and Escalation	12
8	Investigation and Scoping	13
9	Containment Strategy	14
10	Eradication and Remediation	15
11	Recovery and Return to Service	16
12	Lessons Learned and Improvement	17
13	Communication, Legal, and Regulatory Coordination	18
14	Digital Evidence and Forensic Readiness	19
15	Ransomware and Destructive Attacks	20
16	Cloud and SaaS Incident Response	21
17	Identity and Privileged-Access Incidents	22
18	Third-Party and Supply-Chain Incidents	23
19	Business Continuity Management System	24
20	Continuity Strategies and Procedures	25
21	Disaster Recovery Planning	26
22	Backups and Recovery Assurance	27
23	Crisis Management and Human Factors	29
24	Exercises, Training, and Plan Maintenance	30
25	Compliance Mapping, Evidence Testing, and Metrics	31
26	Open-Source Tools	32
27	Manager's Resilience Playbook	37
28	Junior Analyst Career Guide and Portfolio Lab	38
29	Thirty-Day Plan and Interview Preparation	40
30	Templates, Glossary, Index, and References	42

1. IR, Business Continuity, and Disaster Recovery Foundations

Resilience connects cyber response, critical operations, technology restoration, and leadership.



Incident response is part of continuous cybersecurity risk management

Figure 1. Integrated cyber resilience cycle

Capability	Primary question	Typical owner
Incident response	How do we detect, contain, remove, recover from, and learn from cyber incidents?	Security / incident commander
Business continuity	How will critical products and services continue during disruption?	Business continuity / process owners
Disaster recovery	How will technology and data be restored to approved targets?	IT / system and recovery owners
Crisis management	How will leaders make high-impact decisions and coordinate stakeholders?	Executive crisis team
Emergency / life safety	How will people be protected during physical danger?	Facilities / safety / public authorities

Do not confuse the plans: They must coordinate, but they have different objectives, authorities, triggers, teams, and evidence. One document rarely serves every need well.

2. Governance, Policy, and Roles

Authority, decision rights, contacts, and resources must exist before pressure begins.

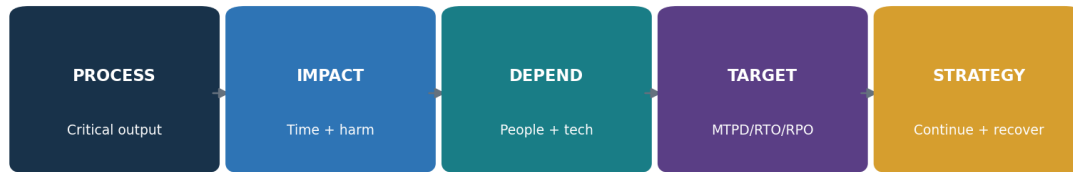
2.1 Governance essentials

- Executive-approved policy, scope, objectives, authorities, risk criteria, and resources.
- Named incident commander, technical lead, continuity leader, recovery lead, communications lead, legal/privacy contacts, and alternates.
- Severity and activation thresholds, escalation paths, emergency change authority, spending authority, and business risk acceptance.
- Secure contact methods, out-of-band communications, call trees, vendors, insurers, regulators, and public authorities.
- Plan ownership, version control, distribution, training, exercise, review, and improvement schedule.

Role	Key decisions
Incident commander	Objectives, priorities, task coordination, status rhythm, escalation
Technical lead	Investigation, scope, containment, eradication, recovery criteria
Business owner	Operational impact, workaround, priority, return-to-service acceptance
Continuity / DR lead	Alternate process/site, recovery sequence, resource conflicts
Legal / privacy	Privilege, preservation, notification analysis, authorities, contracts
Communications	Employees, customers, partners, public, media, message approval
Scribe / evidence custodian	Timeline, decisions, evidence identity, custody, action log
Executive crisis team	Safety, material risk, strategy, resources, external posture

3. Risk Assessment and Business Impact Analysis

A business impact analysis turns vague importance into time-based recovery requirements.



A BIA connects business impact to recovery priorities and resources

Figure 2. BIA reasoning chain

3.1 BIA method

- Define products, services, processes, owners, customers, and minimum acceptable output.
- Estimate safety, legal, customer, financial, operational, privacy, security, and reputational impact as disruption length increases.
- Set maximum tolerable period of disruption (MTPD/MAO) and a recovery time objective (RTO) that fits inside it.
- Set recovery point objective (RPO): the maximum tolerable data loss measured in time.
- Identify people, facilities, technology, data, suppliers, utilities, communications, records, and upstream/downstream dependencies.
- Validate assumptions with process owners and leadership; resolve conflicting priorities.
- Use results to select strategies, recovery tiers, tests, investments, and plan content.

Term	Meaning	Example
MTPD / MAO	Longest tolerable disruption before unacceptable harm	Customer authorization unavailable beyond 24 hours
RTO	Target time to restore a process or resource	Restore service within 8 hours
RPO	Maximum tolerable data loss measured backward from disruption	No more than 30 minutes of transactions lost
Minimum service level	Smallest acceptable capacity during continuity mode	Serve priority customers at 40% capacity
Dependency	Resource another process needs to deliver its output	Identity, DNS, cloud region, people, supplier

Common error: RTO and RPO are business requirements, not backup product settings. Test whether the full end-to-end service can actually meet them.

4. Current NIST Incident Response Model

NIST SP 800-61 Rev. 3 integrates incident response into the six CSF 2.0 Functions.

CSF Function	Incident-response contribution
Govern	Policy, roles, authorities, legal and contractual needs, supplier responsibilities, oversight, improvement
Identify	Assets, services, data, dependencies, risks, vulnerabilities, improvement needs
Protect	Identity, configuration, awareness, data security, maintenance, resilience, protective technology
Detect	Continuous monitoring and adverse-event analysis
Respond	Incident management, analysis, reporting/communication, mitigation
Recover	Recovery-plan execution, restoration, verification, and recovery communication

What changed from Rev. 2: The older preparation–detection/analysis–containment/eradication/recovery–post-incident diagram remains useful operationally, but Rev. 3 supersedes Rev. 2 and frames response as organization-wide cybersecurity risk management.

4.1 Practical operating sequence

- Prepare continuously through governance, identification, and protection.
- Detect a possible adverse event and validate it.
- Manage, analyze, communicate, contain, and mitigate the incident.
- Restore safely and communicate recovery.
- Capture lessons and improve all six Functions.

5. Preparation and Readiness

Preparation reduces confusion, access failures, evidence loss, and dangerous improvisation.

5.1 Readiness checklist

- Current asset, identity, data, application, supplier, log-source, and dependency inventories.
- Protected plans, offline contacts, diagrams, credentials, jump kits, forensic tools, clean devices, licenses, and secure communications.
- Central time synchronization, sufficient logging, endpoint/network/cloud telemetry, detection coverage, retention, and tested access.
- Preapproved containment actions, emergency changes, isolation methods, account suspension, token/key rotation, domain blocking, and system shutdown criteria.
- Evidence preservation, privacy, legal hold, chain-of-custody, insurer, law-enforcement, and notification procedures.
- Known-good images, secure build process, protected backups, restoration order, validation criteria, and business acceptance.
- Role training, tabletop and technical exercises, call-tree tests, and tracked improvements.

5.2 Playbook design

Field	Content
Trigger	Observable condition that starts the playbook
Objectives	What must be protected or learned
Authority	Who may approve disruptive actions
Steps	Decision points, actions, dependencies, and safe alternatives
Evidence	What to capture before and after action
Communication	Audience, channel, cadence, approved facts
Recovery	Entry criteria, validation, monitoring, acceptance
Improvement	Metrics, review, owner, retest

6. Detection and Event Validation

Detection combines technology, human reports, external notice, and context.



Fast triage requires reliable telemetry, context, and clear decision thresholds

Figure 3. Detection-to-case workflow

6.1 Signal sources

- Endpoint, identity, network, email, cloud, application, database, data-loss, physical, vulnerability, and threat-intelligence systems.
- Employees, customers, partners, researchers, suppliers, regulators, law enforcement, insurers, and managed service providers.
- Service health, financial fraud, unusual support activity, configuration change, privileged action, and data-quality anomalies.

6.2 Validation questions

- What exactly generated the signal? Is the source reliable and time synchronized?
- Could approved maintenance, testing, user behavior, or data quality explain it?
- Which user, device, service, tenant, data, region, or supplier is affected?
- What corroborating evidence exists across independent sources?
- Is activity continuing, spreading, privileged, externally exposed, destructive, or safety related?
- What must be preserved before a containment action changes evidence?

7. Triage, Severity, and Escalation

Triage sets priority and starts the right authority, evidence, and communication paths.

Severity factor	Questions
Functional impact	Which products, services, processes, people, or safety outcomes are affected?
Information impact	Was data accessed, changed, destroyed, exposed, encrypted, or unavailable?
Recoverability	Can the problem be contained and restored with available people, time, and resources?
Threat / persistence	Is the actor active, privileged, destructive, sophisticated, or moving laterally?
Scope / concentration	How many systems, identities, locations, customers, or suppliers may share exposure?
Obligation / visibility	Could legal, contractual, regulator, insurer, customer, or public notice apply?
Uncertainty	Which facts are missing, and could they materially increase severity?

7.1 Triage output

- Case identifier, detected time, known start time, reporter, commander, severity, status, and secure workspace.
- Current facts separated from assumptions and hypotheses.
- Affected and potentially affected populations, business impact, evidence preserved, and immediate protection.
- Tasks, owners, deadlines, next update time, escalation, and notification clocks.
- Rationale for severity changes and major decisions.

8. Investigation and Scoping

Investigation builds and tests explanations while the environment and attacker may be changing.

8.1 Investigation method

- Write the initial questions: entry point, identity, action, persistence, privilege, movement, data, command-and-control, impact, and remaining access.
- Create a time-normalized event timeline and record source, time zone, confidence, and gaps.
- Scope from known indicators to related identities, hosts, cloud resources, applications, data, and suppliers; do not rely on one indicator.
- Preserve volatile evidence before shutdown when safe, authorized, and useful.
- Test competing hypotheses and seek disconfirming evidence.
- Document collection method, queries, hashes, versions, limitations, and analyst conclusions.
- Brief decision makers with facts, uncertainty, business effect, options, and recommended next step.

Question	Possible evidence
How did access begin?	Email, identity, endpoint, web, VPN, cloud, vulnerability and support logs
What did the actor do?	Process, command, audit, file, registry, memory, network and cloud activity
What was accessed?	Application, database, object, DLP, query, API and file-access records
Does persistence remain?	Accounts, tokens, keys, scheduled tasks, services, OAuth apps, cloud roles
How far did it spread?	Identity graph, endpoint queries, network flows, DNS, remote access, shared tools
What can be trusted?	Integrity checks, known-good baselines, independent telemetry, rebuild provenance

9. Containment Strategy

Containment limits harm while preserving safety, operations, evidence, and recovery options.



Containment balances evidence, safety, operations, and attacker disruption

Figure 4. Containment decision

9.1 Options

- Isolate endpoint, segment network, block indicator, disable account, revoke sessions, rotate tokens/keys, remove public exposure, stop integration, restrict data, pause deployment, fail over, or shut down.
- Short-term containment may be fast and temporary; long-term containment supports safer operation until eradication.
- Use staged or coordinated action when isolated steps would alert an attacker or break critical service.

9.2 Decision record

- Objective and threat being limited.
- Affected business service, safety, customer, evidence, privacy, and recovery impact.
- Alternatives considered and reason selected.
- Approver, executor, time, commands/change ticket, before-and-after evidence, rollback, and verification.
- Residual exposure and next decision point.

10. Eradication and Remediation

Eradication removes the cause, attacker access, persistence, unsafe changes, and related weaknesses.

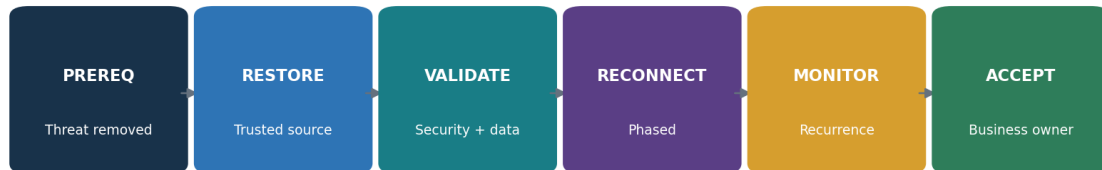
10.1 Eradication work

- Remove malicious files, processes, tasks, services, accounts, applications, rules, access paths, and infrastructure.
- Revoke sessions and tokens; rotate exposed passwords, keys, certificates, secrets, recovery codes, and trust relationships in a safe order.
- Patch or mitigate exploited vulnerabilities; harden configuration; close exposed services; correct identity and network paths.
- Rebuild from trusted sources when integrity cannot be demonstrated.
- Search the full potential population for the same condition and validate no alternate persistence remains.
- Preserve evidence and separate remediation from proof; record every change.

Root cause versus entry point: The entry point explains how this incident began. Root causes may include process, design, ownership, visibility, skills, incentives, or control weaknesses that allowed it to succeed or persist.

11. Recovery and Return to Service

Recovery restores critical service through controlled, verified, and monitored steps.



Return to service is a controlled risk decision, not merely a system restart

Figure 5. Trusted return to service

11.1 Recovery gates

- Containment is stable and recovery will not reconnect to active compromise.
- Restoration source, build pipeline, backups, credentials, dependencies, and administration path are trusted.
- Required security updates, hardening, identity rotation, and monitoring are active.
- Data integrity, completeness, application function, interfaces, capacity, and RTO/RPO results are tested.
- Reconnection is phased; increased monitoring has clear owners and duration.
- Business and technical owners approve return to service, with exceptions and residual risk recorded.

11.2 Recovery evidence

- Recovery sequence and actual timestamps.
- Restored versions, sources, hashes/configuration, data point, and dependency status.
- Security, functional, data-reconciliation, performance, and user-acceptance results.
- RTO/RPO achieved or missed, cause, impact, workaround, and corrective action.
- Enhanced monitoring results and recurrence decision.

12. Lessons Learned and Improvement

Improvement converts experience into safer systems and better decisions.

12.1 After-action process

- Hold a blameless but accountable review soon enough that facts and decisions can be reconstructed.
- Build the factual timeline: signal, recognition, escalation, decisions, containment, eradication, restoration, communication, and closure.
- Compare expected versus actual performance of people, plans, data, tools, suppliers, communications, and recovery.
- Identify contributing conditions and systemic causes, not only individual mistakes.
- Assign specific actions, owners, resources, risk-based dates, interim protection, and success measures.
- Retest the failed capability and update policies, architecture, detections, playbooks, contracts, training, BIA, continuity, and recovery plans.

Weak action	Stronger action
Improve monitoring	Add identity-provider admin events to the SIEM, alert on new privileged role within five minutes, and test monthly
Train staff	Run a targeted exercise for service-desk identity verification and measure failure handling
Fix backups	Add isolated daily copy for Tier 1 database and prove restore within four-hour RTO quarterly
Update plan	Add named alternate decision maker, out-of-band contact, and tested activation step

13. Communication, Legal, and Regulatory Coordination

Communication must be accurate, timely, authorized, audience-specific, and protected.

13.1 Operating rules

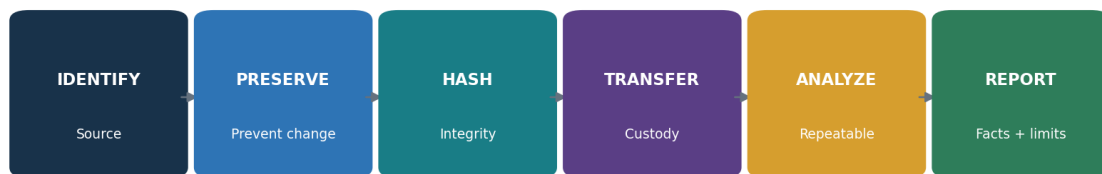
- Maintain one approved fact base with time, source, confidence, owner, and last update.
- Separate operational status, legal analysis, technical hypotheses, and public messages.
- Use secure channels appropriate to possible compromise and preserve required records.
- State what is known, unknown, being done, needed from the audience, and next update time.
- Track notification triggers and clocks by law, regulator, contract, insurer, customer, employee, and jurisdiction.
- Coordinate legal, privacy, communications, human resources, safety, executives, suppliers, insurers, and public authorities.
- Do not speculate, hide material facts, destroy records, or promise timing that responders cannot support.

Audience	Needs
Responders	Objectives, scope, tasks, evidence, hazards, decisions
Executives	Business impact, uncertainty, options, recommendation, resources, next decision
Employees	What happened, safe actions, support, reporting channel, update timing
Customers / partners	Affected service/data, protective action, support, verified updates
Regulator / authority	Required facts, timing, scope, impact, measures, cooperation
Public / media	Approved accurate message, spokesperson, consistent updates

Legal note: Notification and preservation duties are fact- and jurisdiction-specific. Involve qualified counsel early; do not use this manual as a legal determination.

14. Digital Evidence and Forensic Readiness

Forensic readiness makes evidence trustworthy, useful, proportionate, and available when needed.



Forensic readiness protects integrity, traceability, privacy, and usefulness

Figure 6. Evidence integrity and custody

14.1 Evidence record

- Unique item ID, description, source system/device/account, collector, authority, date/time/time zone, location, and reason.
- Collection method, tool/version, settings, original and working copy, cryptographic hash where appropriate, and storage protection.
- Every transfer: from, to, date/time, purpose, signatures or authenticated record, and integrity verification.
- Analysis steps, queries, transformations, time normalization, screenshots/exports, findings, alternative explanation, and limitation.
- Retention, legal hold, privacy/minimization, access log, disclosure, and approved disposal.

Safety and authority: Do not access personal accounts, intercept communications, collect broadly, or perform invasive actions without proper authority. Follow law, policy, privacy, employment, and evidence rules.

15. Ransomware and Destructive Attacks

Ransomware may combine access, theft, extortion, encryption, destruction, and public pressure.

15.1 Immediate priorities

- Protect life and safety; activate incident and crisis leadership.
- Isolate affected systems and networks in a coordinated way; preserve evidence before power-off when safe and useful.
- Secure identity infrastructure, administrative paths, backups, hypervisors, cloud consoles, remote tools, and management systems.
- Determine scope, actor activity, persistence, data access/exfiltration, encryption, business impact, and supplier exposure.
- Use out-of-band communications and known-clean devices/credentials.
- Engage legal counsel, insurer, qualified responders, and appropriate authorities under approved procedures.
- Prioritize trusted restoration of critical services; validate backups and do not reconnect into active compromise.

15.2 Payment decision

- Payment is a legal, safety, ethical, sanctions, business, and risk decision for authorized leadership—not a junior analyst.
- Payment does not guarantee decryption, deletion, silence, or absence of future attacks.
- Preserve facts, authorities, alternatives, insurer conditions, and decision rationale; use qualified counsel and public authorities as appropriate.

16. Cloud and SaaS Incident Response

Cloud response depends on provider telemetry, shared responsibility, tenant control, and support access.

16.1 Cloud investigation

- Preserve provider audit, identity, API, object, network, workload, database, key-management, security, billing, and support logs before retention expires.
- Identify tenant, subscription/project/account, region, resource, identity, role, token, key, automation, application, and provider action.
- Review control-plane and data-plane activity separately.
- Snapshot or export evidence using supported methods; record provider time, identifiers, hashes, and limitations.
- Coordinate provider escalation, legal request, incident notice, subprocessor, and shared-responsibility duties.

16.2 Cloud containment

- Revoke sessions and tokens, disable compromised identities, rotate secrets/keys, restrict policies and networks, quarantine workloads, stop unsafe automation, and preserve recovery paths.
- Avoid deleting resources before evidence, dependency, and rollback needs are understood.
- Validate infrastructure-as-code, images, pipelines, identity federation, logging, and tenant baseline before rebuilding.

17. Identity and Privileged-Access Incidents

Identity compromise can cross endpoints, cloud services, suppliers, and recovery channels.

17.1 Scope

- Password, MFA method, sessions, refresh/access tokens, API keys, OAuth grants, service principals, certificates, recovery methods, delegated access, and privileged roles.
- Authentication success/failure, device, IP, location, impossible travel, registration, consent, role change, mailbox rule, application access, support reset, and audit-log change.
- Related identities, shared devices, admin tools, federated systems, help desk, suppliers, and break-glass accounts.

17.2 Safe recovery order

- Secure trusted administrative access and identity-provider control first.
- Disable or restrict compromised paths while preserving required evidence.
- Revoke sessions/tokens and remove unauthorized factors, roles, applications, rules, and recovery methods.
- Rotate secrets in dependency-aware order; verify service accounts and automation.
- Restore user access through strong identity proofing; monitor for recurrence.
- Investigate how controls were bypassed and test the corrected process.

18. Third-Party and Supply-Chain Incidents

A supplier incident requires shared facts, responsibilities, notification clocks, and recovery decisions.

18.1 Prepare

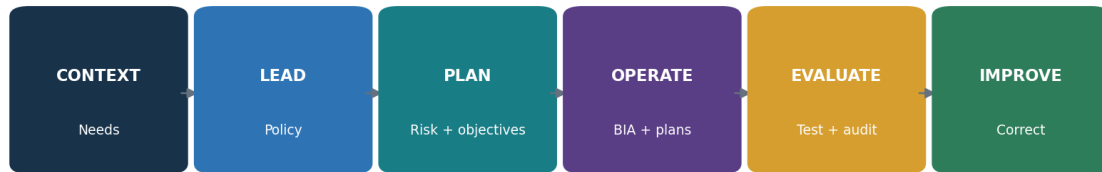
- Keep current supplier services, owners, data, access, integrations, fourth parties, incident contacts, contract terms, and alternatives.
- Define reportable events, notice time and channel, minimum facts, evidence/cooperation, updates, containment, recovery, public communication, and post-incident duties.
- Include critical suppliers in exercises and continuity/exit tests.

18.2 Respond

- Confirm affected product, version, tenant, region, data, accounts, integrations, subprocessors, and time period.
- Separate supplier claims from independently supported facts and record uncertainty.
- Protect the organization's access, keys, sessions, integrations, data flows, and customers.
- Coordinate supplier, internal teams, customers, authorities, insurer, and other affected providers.
- Reassess risk, findings, contract performance, concentration, and exit/continuity options after recovery.

19. Business Continuity Management System

A BCMS makes continuity a governed, measured, and improving management capability.



A business continuity management system turns plans into a managed capability

Figure 7. Business continuity management system

ISO 22301 area	Practical activity
Context	Understand internal/external issues, interested parties, scope, and continuity needs
Leadership	Policy, roles, accountability, integration, and resources
Planning	Risks/opportunities, objectives, planned changes
Support	People, competence, awareness, communication, documented information
Operation	BIA, risk assessment, strategy, procedures, exercises, evaluation
Performance evaluation	Monitoring, measurement, analysis, internal audit, management review
Improvement	Nonconformity, corrective action, and continual improvement

2024 climate amendment: ISO 22301:2019/Amd 1:2024 adds climate-action text to the management-system context requirements. Organizations must consider whether climate change is relevant and recognize that interested parties can have climate-related requirements.

20. Continuity Strategies and Procedures

Continuity strategies keep priority activities within tolerable impact and minimum service levels.

Resource	Strategy examples	Test question
People	Cross-training, alternates, remote work, split teams, contracted support	Can trained alternates perform the process?
Facilities	Alternate site, reciprocal space, remote operation, mobile capability	Can people access a safe usable location?
Technology	High availability, failover, alternate platform, manual mode	Does the end-to-end service meet RTO/RPO?
Data / records	Protected copies, offline records, export, alternate access	Is information complete, current, secure, and usable?
Suppliers	Alternate supplier, reserved capacity, inventory, substitution	Can the alternative deliver within tolerance?
Utilities / communications	Diverse power, network, voice, out-of-band channel	Does common infrastructure create one failure?
Process	Prioritization, reduced service, backlog plan, manual workaround	Can minimum output be sustained safely?

20.1 Continuity procedure

- Activation trigger and authority.
- Priority output, minimum service level, maximum duration, and recovery target.
- People, contact, location, technology, information, supplier, and safety needs.
- Step-by-step workaround with controls, approvals, records, privacy, reconciliation, and backlog recovery.
- Customer/employee communication and status rhythm.
- Return-to-normal criteria, validation, owner acceptance, and after-action review.

21. Disaster Recovery Planning

A disaster recovery plan restores technology in business-priority order.

21.1 NIST SP 800-34 contingency process

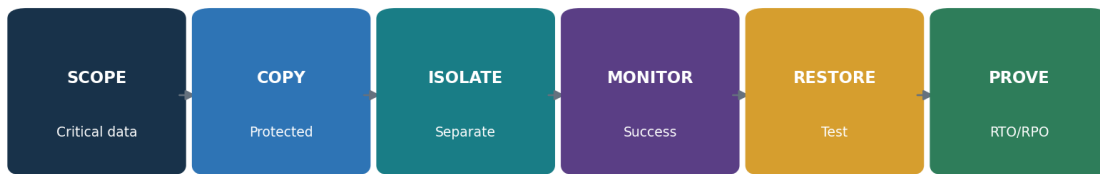
- Develop the contingency planning policy statement.
- Conduct the business impact analysis.
- Identify preventive controls.
- Create contingency strategies.
- Develop the information system contingency plan.
- Ensure plan testing, training, and exercises.
- Ensure plan maintenance.

21.2 DR plan content

- Scope, assumptions, activation, authorities, contacts, vendors, sites, architectures, dependencies, and recovery tiers.
- Damage assessment, declaration, failover, restore, rebuild, validation, reconnection, return to primary, and closure.
- System-by-system runbooks with prerequisites, credentials, clean administration, data points, interfaces, security, testing, and rollback.
- Resource conflicts, capacity, licensing, logistics, communications, and manual workarounds.
- Actual RTO/RPO, exceptions, acceptance, and improvement evidence.

22. Backups and Recovery Assurance

Backups require protected scope, separation, monitoring, restoration tests, and trusted administration.



A backup is useful only when the right data can be restored safely in time

Figure 8. Backup-to-recovery assurance

22.1 Design

- Map critical systems, configurations, identity, keys, code, SaaS data, logs, and dependencies to BIA targets.
- Use multiple protected copies with appropriate separation, immutability/offline control, encryption, access segregation, monitoring, and retention.
- Protect backup consoles, service accounts, deletion, replication, catalogs, recovery credentials, and management networks.
- Avoid replicating corruption or attacker changes without usable historical recovery points.

22.2 Restore test

- Select a representative system and recovery point under an approved scenario.
- Use authorized people, clean administration, documented runbook, and isolated restoration where appropriate.
- Measure actual time and data loss; validate completeness, integrity, security, interfaces, performance, and business use.
- Record failures and workarounds; correct and retest.
- Report whether the full service—not only a file—met RTO, RPO, and minimum service requirements.

23. Crisis Management and Human Factors

Crisis management coordinates high-impact decisions when information is incomplete and time matters.

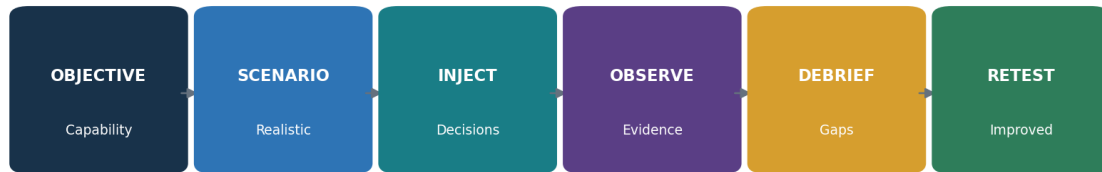
23.1 Leadership rhythm

- Set safety, service, legal, customer, evidence, and recovery objectives in priority order.
- Maintain a common operating picture: facts, uncertainty, business effects, decisions, actions, resources, and next update.
- Assign one decision owner and one action owner; record rationale and time.
- Use short briefings and protected channels; control rumors and conflicting instructions.
- Watch responder fatigue, shift turnover, cognitive bias, stress, personal safety, and family needs.
- Plan relief, food, rest, transportation, accessibility, mental-health support, and respectful handoffs.

Briefing element	Question
Situation	What changed since the last update?
Impact	Who or what is affected now and over time?
Uncertainty	Which missing fact could change the decision?
Objectives	What outcomes matter in the next operating period?
Options	What are benefits, harms, dependencies, and reversibility?
Decision	Who decides by when?
Actions	Who does what, by when, with what evidence?
Communication	Who needs which verified message and when?

24. Exercises, Training, and Plan Maintenance

Exercises should evaluate capability, not reward a rehearsed performance.



Exercises evaluate decisions, coordination, plans, technology, and recovery

Figure 9. Exercise and improvement cycle

Exercise type	Purpose
Checklist / call-tree test	Validate records, contacts, access, and simple steps
Tabletop	Discuss decisions, roles, information, and coordination using a scenario
Simulation	Operate teams and communications in a realistic controlled environment
Technical recovery test	Restore, rebuild, fail over, validate, and measure technology
Parallel test	Run recovery capability without replacing production
Full interruption	Shift actual service under tightly controlled authority; highest risk
Purple-team exercise	Collaboratively test attack, detection, response, and improvement

24.1 After-action evidence

- Objective and capability tested, scenario, assumptions, participants, observers, rules, and safety controls.
- Expected actions and measurable success criteria.
- Actual timeline, decisions, communications, tool/plan use, recovery results, and limitations.
- Strengths, gaps, root/contributing causes, risk, owners, dates, interim controls, and retest.

25. Compliance Mapping, Evidence Testing, and Metrics

Frameworks overlap, but evidence must be tested against the exact applicable requirement.

Source	Relevant focus	Caution
NIST SP 800-61 Rev. 3	CSF 2.0 Community Profile for organization-wide incident response	Supersedes Rev. 2; tailor the Profile
NIST SP 800-34 Rev. 1 Update 1	Federal information-system contingency planning process	Older but current NIST final; adapt outside federal use
ISO 22301:2019 + Amd 1:2024	Requirements for a business continuity management system	Copyrighted standard; certification scope matters
ISO 22313:2020	Guidance for using ISO 22301	Guidance is not certification
SOC 2	Availability, security, confidentiality, privacy, processing commitments and controls	Review exact report scope, period, tests, exceptions
ISO/IEC 27001:2022	Incident management, continuity readiness, backup, logging, suppliers	Statement of Applicability and certificate scope vary
PCI DSS v4.0.1	Incident response, testing, service providers, backups and recovery-related controls	Validate exact cardholder-data environment scope
HIPAA	Contingency plan, incident procedures, backup, DR, emergency operation	Legal applicability and implementation require fact-specific analysis
GDPR	Security, breach assessment/notification, processor cooperation, resilience/restoration	Legal roles, risk, timing, jurisdiction require counsel

25.1 Evidence test

- Define criteria, scope, period, systems, processes, suppliers, and exclusions.
- Validate the complete population: incidents, alerts, plans, tests, recoveries, suppliers, backups, systems, or actions.
- Inspect design and operating evidence; inquiry alone is weak.
- Sample defensibly or test the full population; record method and limitations.
- Evaluate exceptions, patterns, impact, cause, compensating controls, and residual risk.
- Track corrective action and independently retest before closure.

Metric	Definition	Warning
Mean time to detect	Time from event start/first evidence to detection	Start time may be uncertain
Mean time to contain	Detection/activation to verified containment	Average can hide severe outliers
Recovery target achievement	Tests/incidents meeting RTO and RPO ÷ in-scope tests/incidents	Define full-service success
Playbook exercise coverage	Critical scenarios exercised ÷ approved critical scenarios	Discussion is not technical proof
Corrective action age	Days open by severity and owner	Closure requires retest
Backup restore success	Successful representative restores ÷ scheduled tests	File restore may not prove service recovery
Incident recurrence	Repeat incidents linked to same uncorrected cause	Classification consistency matters

26. Open-Source Tools

Open-source tools support case management, evidence, detection, investigation, automation, and reporting.

Tool	Purpose
TheHive	Case management and incident collaboration
Cortex	Observable analysis and response actions
MISP	Threat-information sharing and correlation
Wazuh	Endpoint monitoring, log analysis, file integrity, and alerts
Velociraptor	Endpoint visibility and incident-response collection
Volatility 3	Memory forensics
Autopsy	Disk and file-system forensic analysis
Timesketch	Collaborative forensic timelines
Plaso / log2timeline	Timeline extraction from forensic artifacts
osquery	Endpoint state and threat-hunting queries
Zeek	Network security telemetry and protocol metadata
Suricata	Network intrusion detection and prevention
YARA	Pattern matching for files and memory
Sigma	Portable log-detection rules
DFIR-IRIS	Incident response and investigation case management
GRR Rapid Response	Remote live forensics at endpoint scale
Shuffle	Security orchestration and automation
OpenSearch	Search, analytics, dashboards, and security logs

Authorization and evidence safety: Use tools only on systems, networks, accounts, repositories, and data you own or have written authority to examine. Isolate labs, protect evidence, minimize personal data, log actions, and never let automation perform destructive steps without approved safeguards.

26.1 TheHive

Purpose: Case management and incident collaboration. Official project: [TheHive](#)

Safe quick start: Create a lab case, define tasks and severity, add synthetic observables, record decisions, protect permissions, and close only after review.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.2 Cortex

Purpose: Observable analysis and response actions. Official project: [Cortex](#)

Safe quick start: Connect only approved analyzers in a lab, submit synthetic observables, validate results, restrict responders, and retain action logs.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.3 MISP

Purpose: Threat-information sharing and correlation. Official project: [MISP](#)

Safe quick start: Create a private lab event, add synthetic indicators with context and handling markings, correlate, export only approved data, and expire stale indicators.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.4 Wazuh

Purpose: Endpoint monitoring, log analysis, file integrity, and alerts. Official project: [Wazuh](#)

Safe quick start: Enroll a lab endpoint, generate a harmless event, confirm collection and alerting, investigate, document coverage, and tune carefully.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.5 Velociraptor

Purpose: Endpoint visibility and incident-response collection. Official project: [Velociraptor](#)

Safe quick start: Use an isolated authorized lab, collect a narrow artifact, record scope and access, verify results, and remove retained lab data according to policy.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.6 Volatility 3

Purpose: Memory forensics. Official project: [Volatility 3](#)

Safe quick start: Analyze a legally obtained training memory image, record hashes and tool version, run focused plugins, validate findings, and preserve notes.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.7 Autopsy

Purpose: Disk and file-system forensic analysis. Official project: [Autopsy](#)

Safe quick start: Create a case from a training image, verify the source hash, use read-only analysis, tag evidence, export a report, and secure the case.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.8 Timesketch

Purpose: Collaborative forensic timelines. Official project: [Timesketch](#)

Safe quick start: Import a synthetic timeline, label key events, search hypotheses, record analyst conclusions and uncertainty, and control access.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.9 Plaso / log2timeline

Purpose: Timeline extraction from forensic artifacts. Official project: [Plaso / log2timeline](#)

Safe quick start: Process a training image or approved artifact set, document parser and time-zone choices, export a timeline, and validate key events.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.10 osquery

Purpose: Endpoint state and threat-hunting queries. Official project: [osquery](#)

Safe quick start: Run read-only queries in a lab, document the query and population, compare endpoints, validate anomalies, and avoid uncontrolled collection.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.11 Zeek

Purpose: Network security telemetry and protocol metadata. Official project: [Zeek](#)

Safe quick start: Use a lab sensor or an approved packet capture, generate safe traffic, inspect logs, build a timeline, and document encrypted traffic limits.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.12 Suricata

Purpose: Network intrusion detection and prevention. Official project: [Suricata](#)

Safe quick start: Use a lab interface, update approved rules, generate test traffic, validate alerts, tune with change control, and preserve versions.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.13 YARA

Purpose: Pattern matching for files and memory. Official project: [YARA](#)

Safe quick start: Test a narrow rule against harmless samples, document rule source and false positives, peer-review it, and scan only authorized data.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.14 Sigma

Purpose: Portable log-detection rules. Official project: [Sigma](#)

Safe quick start: Select a rule, map it to available fields, convert for a lab platform, test with synthetic logs, tune, peer-review, and track versions.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.15 DFIR-IRIS

Purpose: Incident response and investigation case management. Official project: [DFIR-IRIS](#)

Safe quick start: Create a fictional case, assign tasks, record timeline and evidence, restrict roles, generate a report, and test backup/export.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.16 GRR Rapid Response

Purpose: Remote live forensics at endpoint scale. Official project: [GRR Rapid Response](#)

Safe quick start: Deploy only in an isolated authorized environment, approve a narrow collection flow, verify audit logs, and control retained results.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.17 Shuffle

Purpose: Security orchestration and automation. Official project: [Shuffle](#)

Safe quick start: Build a lab workflow with harmless inputs and approval gates, test failure paths, log every action, and keep destructive actions disabled.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

26.18 OpenSearch

Purpose: Search, analytics, dashboards, and security logs. Official project: [OpenSearch](#)

Safe quick start: Ingest synthetic logs, normalize time and fields, create a focused query and dashboard, restrict access, and document retention.

Evidence: written authority and scope, source identity, date/time/time zone, tool and version, configuration/query, hashes where appropriate, raw result, analyst validation, limitation, action, and review. Restrict access and preserve an unaltered source copy when required.

27. Manager's Resilience Playbook

Managers create resilience by setting authority, funding preparation, challenging evidence, and removing blockers.

Area	Manager question	Red flag
Governance	Are authority, alternates, severity, escalation, spending, and emergency changes clear?	No decision maker after hours
Readiness	Are inventories, logs, contacts, access, tools, communications, and clean recovery resources tested?	Plan exists but access fails
Response	Are facts, uncertainty, objectives, actions, evidence, and next update controlled?	Conflicting teams or undocumented decisions
Continuity	Can critical output continue within tolerable impact?	Workaround ignores safety, privacy, or reconciliation
Recovery	Can complete services meet tested RTO/RPO from trusted sources?	Backup success reported without restore proof
Suppliers	Are critical contacts, duties, dependencies, and alternatives exercised?	One provider is a hidden common dependency
People	Are shifts, handoffs, rest, safety, and psychological strain managed?	Exhausted responders making critical decisions
Improvement	Are severe actions funded, owned, measured, and retested?	Same gap appears in later exercises/incidents

27.1 Executive questions

- What is the current business and safety impact?
- What facts support the conclusion, and what remains uncertain?
- What are the next two decisions, who owns them, and when are they needed?
- Which action could create irreversible harm or destroy evidence?
- Can critical services continue, and for how long?
- Are legal, privacy, contractual, insurer, customer, and authority obligations being tracked?
- What resources or business choice is blocking containment or recovery?
- How will we verify recovery and prevent recurrence?

28. Junior Analyst Career Guide and Portfolio Lab

Junior analysts earn trust through disciplined case records, evidence handling, technical curiosity, and clear writing.



Junior analysts show judgment through careful evidence and clear communication

Figure 10. Junior resilience analyst pathway

28.1 Common roles

- Junior Incident Response Analyst
- SOC Analyst
- Cybersecurity Operations Analyst
- DFIR Analyst (junior)
- Business Continuity Analyst
- Disaster Recovery Analyst
- Cyber Resilience Analyst
- GRC / IT Risk Analyst

28.2 Typical work

- Validate and enrich alerts; open accurate cases; separate facts from assumptions.
- Build timelines, scope affected populations, preserve approved evidence, and record queries/actions.
- Follow playbooks, escalate severity, coordinate tasks, and prepare status summaries.
- Track containment, remediation, recovery evidence, corrective actions, and retests.
- Maintain contacts, plans, BIA/dependency data, recovery runbooks, exercise records, and metrics.
- Use authorized open-source tools in a lab and explain limitations.

28.3 Fictional portfolio lab

- Create a fictional 80-person organization with cloud email, endpoints, SaaS CRM, web application, customer data, suppliers, and a critical billing process.
- Write a BIA with impact over time, dependencies, MTPD, RTO, RPO, and minimum service level.
- Build incident policy, RACI, severity matrix, contacts, communications, ransomware, identity, cloud, and supplier playbooks.
- Use synthetic logs to investigate a fictional compromised account; create a timeline, scope memo, containment record, and manager update.
- Analyze a legal training disk or memory image with Autopsy or Volatility; document source, hash, method, findings, and limits.
- Create a DR runbook and conduct a safe restore test with actual timings and data validation.
- Run a tabletop and produce an after-action report with tracked and retested improvements.
- Publish only sanitized fictional artifacts and state that the work is educational, not a real investigation or certification.

29. Thirty-Day Plan and Interview Preparation

A focused month can build entry-level incident and resilience capability.

Days	Focus	Deliverable
1–3	IR/BC/DR/crisis concepts and current NIST model	Concept map and RACI
4–6	Risk, BIA, dependencies, RTO/RPO	Business impact analysis
7–9	Preparation, logging, contacts, playbooks	Readiness checklist and two playbooks
10–12	Detection, triage, severity, cases	Synthetic alert case
13–15	Investigation, timeline, evidence	Timeline and evidence record
16–18	Containment, eradication, recovery	Decision and recovery workpapers
19–21	Continuity, DR, backup restore	Continuity procedure and restore test
22–24	Cloud, identity, ransomware, suppliers	Four scenario summaries
25–27	Exercise and after-action review	Tabletop package and improvement plan
28–30	Metrics, portfolio, interviews	Dashboard and five STAR stories

29.2 What is the difference between IR, BC, and DR?

IR manages cyber incidents, BC maintains critical business outputs during disruption, and DR restores technology and data. They coordinate but have different objectives.

29.3 What is NIST SP 800-61 Rev. 3?

The current NIST incident-response guidance, finalized in 2025, expressed as a CSF 2.0 Community Profile across Govern, Identify, Protect, Detect, Respond, and Recover.

29.4 RTO versus RPO?

RTO is the target time to restore; RPO is the maximum tolerable data loss measured in time.

29.5 How do you triage an incident?

Validate the signal, assess functional and information impact, recoverability, threat, scope, obligations, and uncertainty, then assign severity and escalation under approved criteria.

29.6 What makes evidence reliable?

Known source, authorized repeatable collection, preserved integrity, timestamps, hashes when appropriate, custody, protected storage, and documented limitations.

29.7 When is recovery complete?

When threat removal is stable, trusted restoration and security/functional/data tests succeed, monitoring is active, and authorized business and technical owners accept return to service.

29.8 How do you close an improvement?

Implement the specific action and retest the failed capability against defined success criteria.

29.9 What should a junior analyst avoid?

Unauthorized access, destructive action, unsupported conclusions, changing original evidence, hiding uncertainty, or promising legal outcomes.

29.10 Questions to ask the employer

- Which incident and resilience scenarios matter most?
- How are severity, command, after-hours escalation, and business acceptance handled?
- What telemetry, case, forensic, continuity, and recovery tools are approved?
- How often are critical restorations and supplier incidents exercised?
- How are junior actions reviewed and evidence protected?
- What would success look like in the first 90 days?

30. Templates, Glossary, Index, and References

Reusable work structures, key terms, a subject index, and official sources.

30.1 Incident case record

Field	Entry
Case/commander/severity	_____
Trigger / detected/known start	_____
Facts/assumptions/hypotheses	_____
Affected and potential scope	_____
Business/data/safety impact	_____
Evidence/timeline/custody	_____
Objectives/decisions/actions	_____
Containment/eradication	_____
Recovery/validation/acceptance	_____
Communication/obligations	_____
Lessons/action/retest	_____

30.2 BIA and continuity record

Field	Entry
Product/service/process/owner	_____
Minimum acceptable output	_____
Impact by time / MTPD	_____
RTO / RPO	_____
People/facility/technology	_____
Data/supplier/utility dependencies	_____
Continuity strategy/workaround	_____
Activation/communication	_____
Return/reconciliation	_____
Test/result/improvement	_____

30.3 Evidence and chain-of-custody record

Field	Entry
Item ID/description / source	_____
Authority/purpose	_____
Collector/date / time zone	_____
Method/tool / version	_____
Original hash/working copy	_____
Storage/access/privacy	_____
Transfer from/to / purpose	_____
Analysis/result/limitations	_____
Retention / legal hold	_____
Review/disposition	_____

30.4 Exercise and corrective-action record

Field	Entry
Objective/capability	_____
Scenario/assumptions/safety	_____

Field	Entry
Participants/observers	
Expected success criteria	
Actual timeline/decisions	
Strengths/gaps/evidence	
Cause/risk / interim control	
Action/owner / due date	
Retest/evidence / result	
Management review	

30.5 Glossary

Term	Meaning
Adverse event	An occurrence that may have a negative consequence.
BCMS	Business continuity management system.
BIA	Business impact analysis.
Business continuity	Capability to continue delivery of products and services at acceptable capacity during disruption.
Chain of custody	Documented control and transfer history of evidence.
Containment	Action to limit incident spread or impact.
Crisis management	Leadership and coordination of high-impact, uncertain situations.
Disaster recovery	Restoration of technology, data, and supporting infrastructure after disruption.
Eradication	Removal of cause, persistence, unsafe changes, and related weaknesses.
Incident	Occurrence that jeopardizes confidentiality, integrity, availability, or violates security policy; use the organization's approved definition.
MTPD / MAO	Maximum tolerable period of disruption / maximum acceptable outage.
Playbook	Scenario-focused response steps, decisions, authority, and evidence.
Recovery	Restoration and verification of service and controls.
RPO	Maximum tolerable data loss measured in time.
RTO	Target time to restore an activity or resource.
Tabletop exercise	Discussion-based evaluation using a scenario and decision questions.

30.6 Subject index

Subject	Chapter
Backups	22
BIA	3, 20
Business continuity	19–20
Cloud incidents	16
Communication	13, 23
Containment	9
Crisis management	23
Detection/triage	6–7
Digital evidence	14
Disaster recovery	21–22
Exercises	24
Identity incidents	17
Investigation	8
Junior analyst	28–29
Lessons learned	12
Manager	27
Metrics/compliance	25
NIST SP 800-61 Rev. 3	4, 25
Open-source tools	26
Ransomware	15
Recovery	11, 21–22
RTO / RPO	3, 21–22
Supplier incidents	18

30.7 Official references

- [NIST SP 800-61 Rev. 3 — Incident Response Recommendations](#)
- [NIST Incident Response Project](#)
- [NIST Cybersecurity Framework 2.0](#)
- [NIST SP 800-34 Rev. 1 Update 1 — Contingency Planning](#)
- [CISA Cybersecurity Incident and Vulnerability Response Playbooks](#)
- [CISA StopRansomware Guide](#)
- [CISA Ransomware Response Checklist](#)
- [CISA Tabletop Exercise Packages](#)
- [CISA Incident Response Plan Basics](#)
- [ISO 22301:2019](#)
- [ISO 22301:2019/Amd 1:2024](#)
- [ISO 22313:2020](#)
- [ISO/TS 22317:2021 — BIA guidance](#)
- [NIST Computer Security Incident Handling Guide project resources](#)

Final reminder: Threats, technology, laws, contracts, standards, official interpretations, tools, contacts, and organizational dependencies change. Verify current authoritative sources and approved plans before a real incident or recovery decision.